UNIVERSIDAD NACIONAL DEL ALTIPLANO – PUNO
FACULTAD DE INGENIERÍA MECÁNICA ELÉCTRICA, ELECTRÓNICA Y SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



Análisis de Ciberseguridad basado en la Matriz MITRE ATTCK: Caso de Estudio aulavirtual2.unap.edu.pe

Estudiante: Choquepata Puma Renso Erik

Curso: TÓPICOS EN CIBERSEGURIDAD

Docente: Ing. Ticona Yanqui Fidel

Ciclo: IX

Puno, Perú

Índice general

1. Reconocimiento (Reconnaissance – TA0043) 1
- 1.1. Definición de la táctica . . . 1
- 1.2. Objetivo del reconocimiento . . . 1
- 1.3. Herramientas utilizadas . . . 1
- 1.4. Procedimiento y resultados . . . 2
  - 1.4.1. WHOIS – punto de partida . . . 2
  - 1.4.2. Resolución DNS (dig) . . . 2
  - 1.4.3. Escaneo de puertos (nmap) . . . 3
  - 1.4.4. Identificación de tecnología web . . . 3
  - 1.4.5. Auditoría del servicio SSH (ssh-audit) . . . 4
- 1.5. Evidencias (capturas de pantalla) . . . 4
- 1.6. Síntesis de hallazgos . . . 6
- 1.7. Recomendaciones . . . 6

2. Desarrollo de Recursos (Resource Development – TA0042) 8
- 2.1. Definición de la táctica . . . 8
- 2.2. Aplicación hipotética al objetivo . . . 8
- 2.3. Herramientas asociadas (referenciales) . . . 8

3. Acceso Inicial (Initial Access – TA0001) 10
- 3.1. Definición de la táctica . . . 10
- 3.2. Aplicación hipotética al objetivo . . . 10
- 3.3. Herramientas asociadas (referenciales) . . . 10
- 3.4. Nota ética . . . 11

4. Ejecución (Execution – TA0002) 12
- 4.1. Definición de la táctica . . . 12
- 4.2. Aplicación hipotética al objetivo . . . 12
- 4.3. Herramientas asociadas (referenciales) . . . 12
- 4.4. Nota ética . . . 12

5. Persistencia (Persistence – TA0003) 13
- 5.1. Definición de la táctica . . . 13
- 5.2. Aplicación hipotética al objetivo . . . 13
- 5.3. Herramientas asociadas (referenciales) . . . 13
- 5.4. Nota ética . . . 13

6. Escalada de Privilegios (Privilege Escalation – TA0004) 14
6.1. Definición de la táctica . . . 14
6.2. Aplicación hipotética al objetivo . . . 14
6.3. Herramientas asociadas (referenciales) . . . 14
6.4. Nota ética . . . 14

7. Sigilo (Stealth / Defense Evasion – TA0005) 15
7.1. Definición de la táctica . . . 15
7.2. Aplicación hipotética al objetivo . . . 15
7.3. Herramientas asociadas (referenciales) . . . 15
7.4. Nota ética . . . 16

8. Alteración de Defensas (Impair Defenses – T1562) 17
8.1. Definición de la técnica . . . 17
8.2. Aplicación hipotética al objetivo . . . 17
8.3. Herramientas asociadas (referenciales) . . . 17
8.4. Nota ética . . . 18

9. Acceso a Credenciales (Credential Access – TA0006) 19
9.1. Definición de la táctica . . . 19
9.2. Aplicación hipotética al objetivo . . . 19
9.3. Herramientas asociadas (referenciales) . . . 19
9.4. Nota ética . . . 20

10. Descubrimiento (Discovery – TA0007) 21
10.1. Definición de la táctica . . . 21
10.2. Aplicación hipotética al objetivo . . . 21
10.3. Herramientas asociadas (referenciales) . . . 21
10.4. Nota ética . . . 21

11. Movimiento Lateral (Lateral Movement – TA0008) 22
11.1. Definición de la táctica . . . 22
11.2. Aplicación hipotética al objetivo . . . 22
11.3. Herramientas asociadas (referenciales) . . . 22
11.4. Nota ética . . . 23

12. Recolección (Collection – TA0009) 24
12.1. Definición de la táctica . . . 24
12.2. Aplicación hipotética al objetivo . . . 24
12.3. Herramientas asociadas (referenciales) . . . 24
12.4. Nota ética . . . 24

13. Mando y Control (Command and Control – TA0011) 25
13.1. Definición de la táctica . . . 25
13.2. Aplicación hipotética al objetivo . . . 25
13.3. Herramientas asociadas (referenciales) . . . 25
13.4. Nota ética . . . 25

14.Exfiltración (Exfiltration – TA0010) **26**
14.1. Definición de la táctica 26
14.2. Aplicación hipotética al objetivo 26
14.3. Herramientas asociadas (referenciales) 26
14.4. Nota ética 26

15.Impacto (Impact – TA0040) **27**
15.1. Definición de la táctica 27
15.2. Aplicación hipotética al objetivo 27
15.3. Herramientas asociadas (referenciales) 27

16.Mitigaciones y Defensas **28**
16.1. Introducción 28
16.2. Mitigaciones priorizadas (hallazgos reales del reconocimiento) 28
16.3. Mitigaciones por táctica MITRE ATT&CK 29
16.4. Recomendación final 30

Capítulo 1

Reconocimiento (Reconnaissance – TA0043)

1.1. Definición de la táctica

Según la matriz MITRE ATT&CK, la táctica de **Reconocimiento (TA0043)** agrupa las técnicas que un adversario emplea para recopilar información sobre un objetivo antes de intentar comprometerlo. Esta información puede incluir infraestructura de red, tecnologías utilizadas, personal, y cualquier otro dato que facilite fases posteriores del ataque. A diferencia de otras tácticas, el reconocimiento suele ser pasivo o de bajo impacto sobre el objetivo.

1.2. Objetivo del reconocimiento

El presente capítulo documenta el reconocimiento realizado, con fines académicos y bajo autorización del docente del curso, sobre el dominio institucional de la Universidad Nacional del Altiplano, con enfoque en el subdominio:

`https://aulavirtual2.unap.edu.pe`

Las evidencias de esta sección corresponden a los comandos ejecutados sobre el dominio `unap.edu.pe` y sus subdominios (`www`, `intranet`), replicando el mismo procedimiento descrito aquí sobre `aulavirtual2.unap.edu.pe` para completar el análisis específico de dicho subdominio.

1.3. Herramientas utilizadas

Herramienta	Propósito
`whois`	Consulta de datos de registro del dominio (registrante, contacto administrativo, servidores de nombres).
`dig` (paquete `bind9-dnsutils`)	Resolución de registros DNS (A, NS) para obtener direcciones IP y servidores autoritativos.

Herramienta	Propósito
`nmap`	Escaneo activo de puertos y detección de versiones de servicios (T1595 – Active Scanning).
`curl`	Obtención de cabeceras HTTP del servidor web.
`ssh-audit`	Auditoría de algoritmos criptográficos soportados por el servicio SSH.
`openssl`	Verificación del certificado SSL/TLS del servidor.

1.4. Procedimiento y resultados

1.4.1. WHOIS – punto de partida

El reconocimiento inicia con `whois`, por ser una consulta pública, pasiva y gratuita que no genera tráfico hacia el servidor objetivo (la información proviene del registrador del dominio, en este caso NIC.PE).

```
$ whois unap.edu.pe

Domain Name: unap.edu.pe
Sponsoring Registrar: NIC.PE
Domain Status: ok
Registrant Name: universidad nacional del altiplano
Admin Name: Pedro Pascual Barriga Gamica
Admin Email: nicadmin@unap.pe
Name Server: ns.rcp.net.pe
Name Server: ns2.rcp.net.pe
```

Hallazgos:

- El dominio está registrado ante **NIC.PE** (registrador oficial para dominios `.pe`).
- El contacto administrativo y el correo de administración están expuestos públicamente.
- Los servidores de nombres pertenecen a **RCP (Red Científica Peruana)**, proveedor externo de servicios DNS, no a infraestructura propia de la UNAP.

1.4.2. Resolución DNS (dig)

A partir de los servidores de nombres identificados, se resolvieron los subdominios relevantes:

```
$ dig www.unap.edu.pe A +short
161.132.24.61

$ dig intranet.unap.edu.pe A +short
161.132.24.29

$ dig unap.edu.pe NS
unap.edu.pe. NS NS2.RCP.NET.pe.
unap.edu.pe. NS NS.RCP.NET.pe.
```

Nota metodológica: se identificó que el dominio raíz `unap.edu.pe` no posee un registro `A` propio (solo registros `NS`); únicamente los subdominios (`www`, `intranet`, y por extensión `aulavirtual2`) resuelven a una dirección IP. Es un error común confundir el registro `NS` del dominio raíz con la IP real del servidor web, error que se identificó y corrigió durante el proceso.

1.4.3. Escaneo de puertos (nmap)

Con la IP del servidor web identificada, se ejecutó un escaneo de puertos con detección de versión. Dado que el host no respondió a las sondas de `ping` por defecto, se utilizó la bandera `-Pn` para omitir esa verificación:

```
$ nmap -sV -Pn 161.132.24.61

PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 8.9p1 Ubuntu 3ubuntu0.17 (Ubuntu Linux; protocol 2.0)
80/tcp open http nginx
113/tcp closed ident
443/tcp open ssl/http nginx
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Hallazgos:

- Puertos **80** y **443** abiertos: comportamiento esperado para un servidor web público.
- Puerto **22 (SSH)** abierto al público: expone el servicio de administración remota a cualquier origen en Internet.
- El resto de puertos (996 de 1000 analizados) aparecen filtrados, lo que indica presencia de un firewall perimetral.

1.4.4. Identificación de tecnología web

Mediante los scripts `http-headers` y `http-title` de Nmap, y consultas con `curl`, se identificaron las cabeceras de respuesta del servidor:

```
$ nmap -sV --script http-title,http-headers -p 80,443 161.132.24.61

443/tcp open ssl/http nginx
Server: nginx
X-Drupal-Dynamic-Cache: MISS
X-Drupal-Cache: HIT
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
Strict-Transport-Security: max-age=31536000
Content-language: es
http-title: UNAP
```

Hallazgos:

- El servidor web utiliza **nginx** como servidor/proxy.
- Las cabeceras `X-Drupal-Cache` y `X-Drupal-Dynamic-Cache` confirman que el sitio está construido sobre el CMS **Drupal**.

- Se aplican cabeceras de seguridad correctas (`HSTS`, `X-Frame-Options`, `X-Content-Type-Options`, `X-XSS-Protection`), lo cual es una buena práctica de configuración.
- El puerto 80 respondió con `404 Not Found` en las pruebas realizadas, mientras que el contenido real se sirve por HTTPS (443).

1.4.5. Auditoría del servicio SSH (ssh-audit)

Dado que el puerto 22 estaba expuesto públicamente, se realizó una auditoría de los algoritmos criptográficos soportados:

```
$ ssh-audit 161.132.24.61

(gen) software: OpenSSH 8.9p1
(kex) ecdh-sha2-nistp256 -- [fail] curva sospechosa de estar comprometida por la
    NSA
(kex) ecdh-sha2-nistp384 -- [fail] curva sospechosa de estar comprometida por la
    NSA
(kex) ecdh-sha2-nistp521 -- [fail] curva sospechosa de estar comprometida por la
    NSA
(key) ecdsa-sha2-nistp256 -- [fail] curva sospechosa + generador de numeros
   aleatorios debil
(mac) hmac-sha1 -- [fail] algoritmo de hash SHA-1 roto
(mac) hmac-sha1-etm -- [fail] algoritmo de hash SHA-1 roto
ssh-auth-methods: publickey, password
```

Hallazgos:

- El servidor **acepta autenticación por contraseña** (`password`), además de llave pública – esto amplia la superficie de ataque frente a fuerza bruta o diccionario si las credenciales son débiles.
- Se ofrecen algoritmos de intercambio de llaves basados en curvas elípticas NIST, consideradas por la comunidad de seguridad como potencialmente comprometidas.
- Se ofrecen algoritmos MAC basados en **SHA-1**, un algoritmo de hash criptográficamente roto.
- De forma positiva, el servidor soporta el modo estricto de intercambio de llaves (`kex-strict-s-v00@openssh.com`), mitigación frente al ataque **Terrapin (CVE-2023-48795)**.

1.5. Evidencias (capturas de pantalla)

A continuación se insertan las capturas de los comandos ejecutados. Reemplazar los archivos de la carpeta `imagenes/` por las capturas propias (`captura1.png` a `captura4.png`).

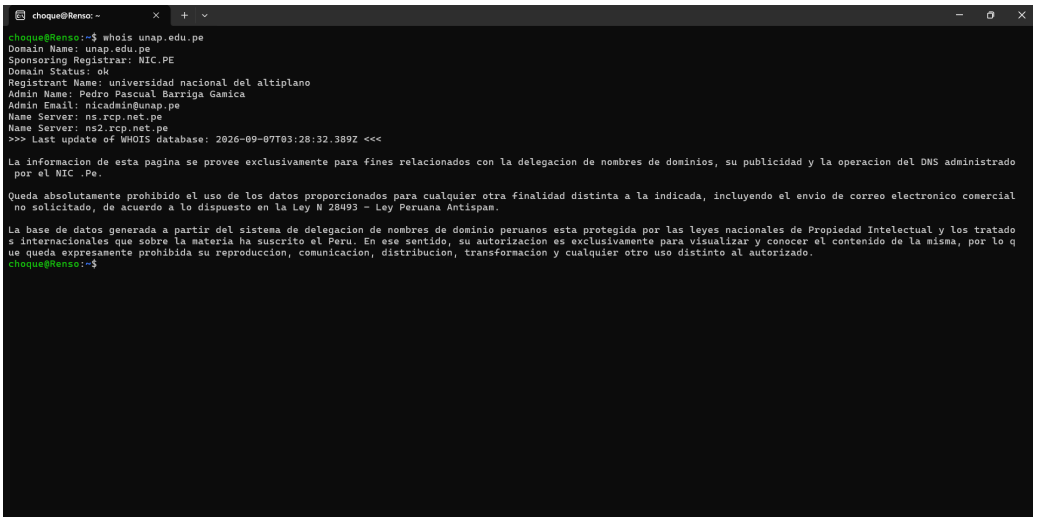


Figura 1.1: Consulta WHOIS del dominio unap.edu.pe

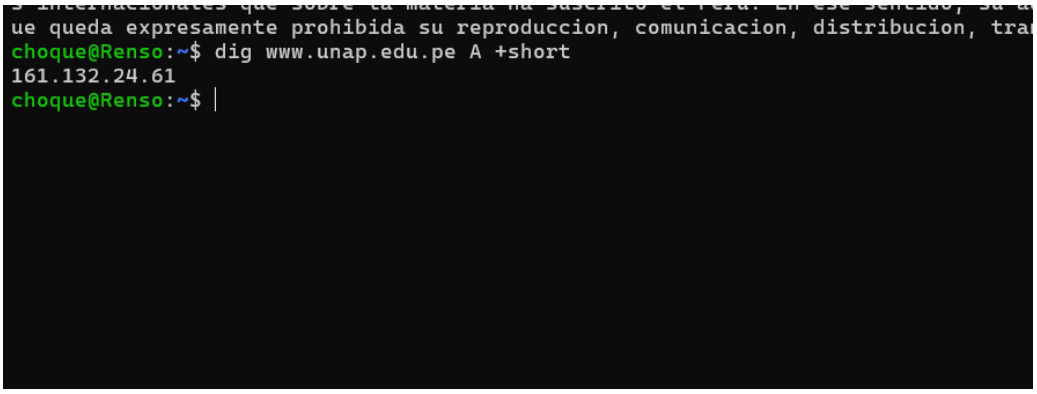


Figura 1.2: Resolución DNS con dig (registros A y NS)

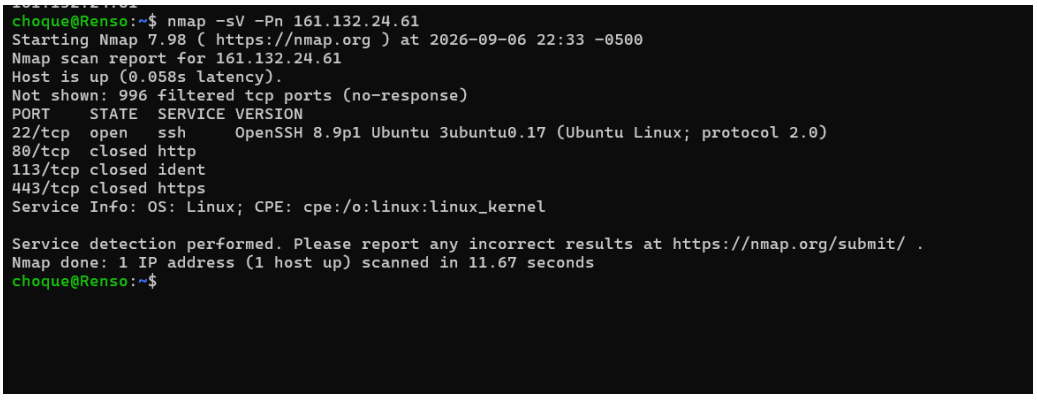


Figura 1.3: Escaneo de puertos y versiones con nmap

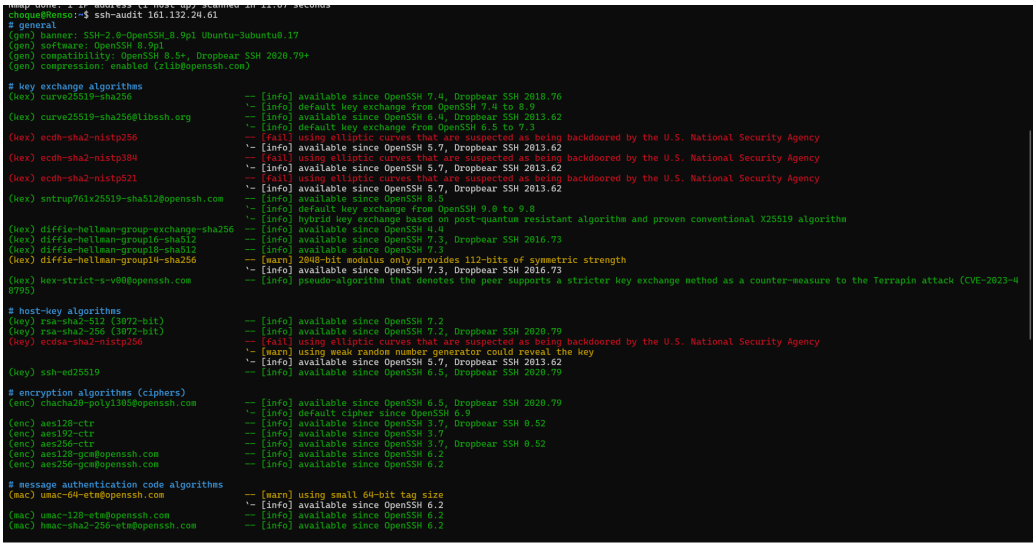


Figura 1.4: Auditoría de algoritmos SSH con ssh-audit

1.6. Síntesis de hallazgos

Hallazgo	**Riesgo asociado**
SSH (puerto 22) expuesto públicamente con autenticación por contraseña habilitada	Superficie de ataque para intentos de fuerza bruta / diccionario de credenciales (táctica Credential Access)
Algoritmos criptográficos débiles en SSH (SHA-1, curvas NIST)	Posible debilitamiento de la confidencialidad de la sesión frente a un atacante avanzado
CMS Drupal identificado en el sitio web	Riesgo si la versión del CMS o sus módulos tienen vulnerabilidades conocidas (CVE) sin parchar
Contacto administrativo expuesto en WHOIS	Punto de partida para posibles campañas de ingeniería social / phishing dirigido

1.7. Recomendaciones

- Restringir el acceso al puerto 22 mediante lista blanca de IPs o VPN, en lugar de exponerlo a toda Internet.
- Deshabilitar la autenticación por contraseña en SSH y permitir únicamente autenticación por llave pública.
- Retirar del listado de algoritmos SSH aquellos marcados como débiles (SHA-1, curvas NIST cuestionadas), siguiendo la recomendación generada por `ssh-audit`.
- Verificar que la versión de Drupal y sus módulos estén actualizados a la última versión estable disponible.

- Mantener las cabeceras de seguridad HTTP ya presentes (HSTS, X-Frame-Options, etc.), pues reflejan buenas prácticas vigentes.

Capítulo 2

Desarrollo de Recursos (Resource Development – TA0042)

2.1. Definición de la táctica

Agrupa las técnicas mediante las cuales un adversario crea, compra o compromete recursos que utilizará en fases posteriores del ataque: infraestructura (servidores, dominios), cuentas, o herramientas/capacidades propias (malware, certificados).

2.2. Aplicación hipotética al objetivo

A partir de la información obtenida en el reconocimiento (dominio, correo administrativo, tecnología Drupal), un adversario *podría*, de forma puramente teórica:

- Registrar un dominio similar (typosquatting) a `aulavirtual2.unap.edu.pe` para campañas de phishing.
- Adquirir un certificado SSL válido para dar apariencia legítima a un sitio clonado.
- Preparar infraestructura de mando y control (C2) en un VPS externo.

Ninguna de estas acciones fue ejecutada; se documentan únicamente como parte del análisis teórico de la matriz.

2.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
`dnstwist`	Genera variaciones de un dominio para detectar/simular typosquatting.
Gophish	Plataforma de simulación de campañas de phishing con fines de concientización.
Let's Encrypt / Certbot	Emisión de certificados SSL gratuitos (uso legítimo, también aprovechable de forma maliciosa).

Herramienta	**Uso típico**
Proveedores VPS (DigitalOcean, Vultr, etc.)	Adquisición de infraestructura de servidores.

Capítulo 3

Acceso Inicial (Initial Access – TA0001)

3.1. Definición de la táctica

Comprende las técnicas utilizadas para obtener el primer punto de apoyo dentro de la red o sistema objetivo.

3.2. Aplicación hipotética al objetivo

Con base en los hallazgos del capítulo de reconocimiento, las rutas de acceso inicial *teóricamente* más relevantes serían:

- **Exploit de aplicación pública (T1190):** si la versión de Drupal detectada tuviera un CVE público sin parchar (p. ej. familia de vulnerabilidades conocida como "Drupalgeddon").
- **Fuerza bruta / credenciales válidas sobre SSH:** dado que el puerto 22 acepta autenticación por contraseña (hallazgo del Capítulo 1).
- **Phishing (T1566):** dirigido al personal administrativo identificado en el WHOIS.

3.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
Metasploit Framework	Explotación de vulnerabilidades conocidas en aplicaciones web y servicios.
sqlmap	Detección y explotación de inyección SQL en formularios web.
Gophish / SET	Simulación de campañas de phishing.
Hydra / Medusa	Pruebas de fuerza bruta de credenciales (uso exclusivo bajo autorización explícita).

3.4. Nota ética

Ninguna técnica de explotación activa fue ejecutada contra el objetivo real. El uso de herramientas como Hydra o Metasploit contra sistemas de producción sin autorización explícita constituye un delito según la Ley N.º 30096 (Ley de Delitos Informáticos del Perú).

Capítulo 4

Ejecución (Execution – TA0002)

4.1. Definición de la táctica

Incluye las técnicas que permiten ejecutar código controlado por el atacante dentro del sistema comprometido.

4.2. Aplicación hipotética al objetivo

De lograrse un acceso inicial (Capítulo 3), la ejecución de código *podría* materializarse mediante:

- Intérprete de comandos (T1059): ejecución de comandos vía shell Bash tras acceso SSH.
- Explotación de servicio remoto para ejecución de código (si el CVE de Drupal identificado lo permitiera).
- Tareas programadas maliciosas para ejecución diferida.

4.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
Metasploit (módulo meterpreter)	Ejecución remota de comandos tras explotación exitosa.
Empire / Sliver	Frameworks de post-explotación para ejecución de payloads.
Bash / PowerShell	Ejecución nativa de comandos en el sistema comprometido.

4.4. Nota ética

Esta sección es puramente descriptiva; no se generó ni ejecutó ningún payload contra el objetivo.

Capítulo 5

Persistencia (Persistence – TA0003)

5.1. Definición de la táctica

Reúne las técnicas que un adversario emplea para mantener acceso al sistema a través de reinicios, cambios de credenciales u otras interrupciones que podrían cortar su acceso.

5.2. Aplicación hipotética al objetivo

Si un atacante lograra acceso al servidor, *podría* intentar mantenerlo mediante:

- Creación de cuentas nuevas o modificación de cuentas existentes (T1136 / T1098).
- Instalación de una llave SSH propia en `authorized_keys` para acceso persistente sin contraseña.
- Tareas cron maliciosas que reestablezcan el acceso periódicamente (T1053).

5.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
Metasploit (módulos de persistencia)	Automatiza la creación de backdoors persistentes.
cron / systemd timers	Mecanismo nativo de Linux, abusable para persistencia.
ssh-keygen	Generación de llaves para acceso persistente sin contraseña.

5.4. Nota ética

No se realizó ninguna modificación, creación de cuentas ni instalación de mecanismos de persistencia sobre el servidor real.

Capítulo 6

Escalada de Privilegios (Privilege Escalation – TA0004)

6.1. Definición de la táctica

Comprende las técnicas que permiten a un adversario obtener permisos de mayor nivel dentro de un sistema o red (por ejemplo, de usuario estándar a superusuario/root).

6.2. Aplicación hipotética al objetivo

Con acceso inicial de bajo privilegio sobre el servidor Linux identificado, un adversario *podría* intentar:

- Explotar binarios con permisos SUID mal configurados (técnica documentada en GTFOBins).
- Aprovechar vulnerabilidades del kernel de Linux sin parchar.
- Abusar de configuraciones de `sudo` demasiado permisivas.

6.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
LinPEAS	Enumeración automática de vectores de escalada de privilegios en Linux.
GTFOBins	Base de datos de binarios Unix abusables para escapar de restricciones.
Metasploit (local exploit suggester)	Sugiere exploits locales según el kernel detectado.

6.4. Nota ética

Esta técnica requiere acceso previo al sistema; no se dispone de dicho acceso ni se intentó obtenerlo sobre el objetivo real.

Capítulo 7

Sigilo (Stealth / Defense Evasion – TA0005)

7.1. Definición de la táctica

Agrupa las técnicas que un adversario utiliza para evitar ser detectado a lo largo de todo el ataque: ocultar acciones, eliminar rastros o enmascarar la actividad maliciosa como legítima.

7.2. Aplicación hipotética al objetivo

Un adversario con acceso al servidor *podría* intentar pasar desapercibido mediante:

- Eliminación o alteración de registros de acceso (`/var/log`) para borrar evidencia de la intrusión (T1070).
- Uso de nombres de proceso o archivos que imiten servicios legítimos del sistema (masquerading, T1036).
- Ofuscación de comandos o scripts para dificultar su análisis.

7.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
Cobalt Strike (malleable C2 profiles)	Ofuscación de tráfico de mando y control para asemejarlo a tráfico legítimo.
`shred` / `timestomp` (conceptual)	Alteración de metadatos de archivos y borrado seguro de evidencia.
Empire / Sliver	Frameworks con módulos de evasión de defensas incorporados.

7.4. Nota ética

Ninguna acción de esta táctica fue ejecutada; se documenta únicamente el enfoque conceptual esperado en un escenario de ataque real.

Capítulo 8

Alteración de Defensas (Impair Defenses – T1562)

8.1. Definición de la técnica

Dentro de la táctica de Evasión de Defensas, esta técnica agrupa las acciones orientadas a deshabilitar o debilitar mecanismos de seguridad (firewalls, antivirus, sistemas de detección) para facilitar la operación del adversario sin ser detectado.

8.2. Aplicación hipotética al objetivo

Sobre el servidor identificado, un adversario con privilegios suficientes *podría* intentar:

- Deshabilitar o reconfigurar el firewall perimetral que actualmente filtra la mayoría de los puertos (evidenciado en el escaneo Nmap del Capítulo 1).
- Detener servicios de monitoreo o herramientas como `fail2ban`.
- Modificar reglas de `iptables`/`nftables` para abrir puertos adicionales sin ser advertido.

8.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
`iptables` / `nftables`	Administración de reglas de firewall (uso legítimo y potencial abuso).
`systemctl`	Detener o deshabilitar servicios de seguridad instalados.
Metasploit (módulos post-explotación)	Automatiza la desactivación de mecanismos de defensa tras el acceso.

8.4. Nota ética

Esta técnica requiere privilegios administrativos sobre el servidor; no se dispuso ni se intentó obtener dicho nivel de acceso sobre el sistema real.

Capítulo 9

Acceso a Credenciales (Credential Access – TA0006)

9.1. Definición de la táctica

Comprende las técnicas orientadas a robar credenciales como nombres de usuario y contraseñas.

9.2. Aplicación hipotética al objetivo

El hallazgo más relevante del Capítulo 1 para esta táctica es que el servicio SSH del servidor **acepta autenticación por contraseña**. Bajo un escenario de ataque, esto habilitaría:

- Ataques de fuerza bruta o diccionario contra el servicio SSH (T1110).
- Phishing dirigido al personal administrativo identificado en el WHOIS para obtener credenciales directamente.
- Captura de credenciales mediante ataques de tipo Adversary-in-the-Middle si el usuario se conecta desde una red no confiable.

9.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
Hydra	Fuerza bruta de credenciales contra múltiples protocolos (SSH, HTTP, FTP, etc.).
Medusa	Alternativa a Hydra para ataques de fuerza bruta paralelos.
Evilginx2	Phishing avanzado con captura de sesiones (Adversary-in-the-Middle).

9.4. Nota ética

Importante: Hydra y herramientas similares realizan ataques *activos* de intrusión, no reconocimiento. Su uso contra el servidor de la UNAP sin autorización formal y explícita para esta fase específica constituye un delito según la Ley N.º 30096. En el marco de este trabajo, **no se ejecutó ningún intento de fuerza bruta** contra el objetivo; esta sección es exclusivamente documental.

Capítulo 10

Descubrimiento (Discovery – TA0007)

10.1. Definición de la táctica

Incluye las técnicas que un adversario, ya dentro del sistema, utiliza para obtener conocimiento sobre el entorno interno: usuarios, procesos, servicios, topología de red.

10.2. Aplicación hipotética al objetivo

Tras un acceso hipotético al servidor, un adversario podría ejecutar reconocimiento interno mediante:

- Enumeración de usuarios y grupos del sistema (T1087).
- Descubrimiento de la red interna de la universidad desde el propio servidor comprometido (T1018).
- Identificación de otros servicios o bases de datos accesibles desde ese host.

10.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
LinEnum	Script de enumeración de información del sistema Linux.
Nmap (desde el host comprometido)	Escaneo de la red interna una vez dentro del perímetro.
BloodHound	Mapeo de relaciones y privilegios en entornos con Active Directory.

10.4. Nota ética

Requiere acceso previo al sistema; no aplicable en el alcance real de este trabajo, limitado a reconocimiento externo autorizado.

Capítulo 11

Movimiento Lateral (Lateral Movement – TA0008)

11.1. Definición de la táctica

Agrupa las técnicas que permiten a un adversario desplazarse desde un sistema comprometido hacia otros sistemas dentro de la misma red.

11.2. Aplicación hipotética al objetivo

Si el servidor web comprometido tuviera conectividad hacia otros sistemas internos de la UNAP (por ejemplo, bases de datos u otros servidores académicos), un adversario *podría* intentar:

- Reutilizar credenciales válidas obtenidas previamente en otros hosts (T1021 – Remote Services).
- Crear túneles SSH para pivotar hacia segmentos de red internos no expuestos directamente a Internet.

11.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
Chisel	Creación de túneles TCP para pivoting a través de un host comprometido.
ProxyChains	Enrutamiento de tráfico de herramientas de escaneo a través de un pivote.
Impacket (psexec, wmiexec)	Movimiento lateral en entornos Windows/Active Directory.

11.4. Nota ética

No se dispuso de acceso al sistema ni a la red interna de la institución; sección de carácter exclusivamente teórico.

Capítulo 12

Recolección (Collection – TA0009)

12.1. Definición de la táctica

Comprende las técnicas empleadas para reunir información de interés para el adversario antes de su exfiltración: bases de datos, archivos, capturas de pantalla, entre otros.

12.2. Aplicación hipotética al objetivo

En un escenario de compromiso completo, un adversario *podría* recolectar:

- Bases de datos del CMS Drupal (posibles datos de usuarios, notas, calificaciones si se trata de un aula virtual).
- Archivos de configuración con credenciales embebidas (T1005 – Data from Local System).
- Capturas de pantalla o registros de actividad de administradores.

12.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
mysqldump / pg_dump	Exportación de bases de datos (uso legítimo, potencial abuso tras acceso no autorizado).
`find` / `grep` recursivo	Búsqueda de archivos con posibles credenciales embebidas (`.env`, `settings.php`).

12.4. Nota ética

No se accedió, extrajo ni intentó extraer ningún dato del sistema real; sección exclusivamente conceptual.

Capítulo 13

Mando y Control (Command and Control – TA0011)

13.1. Definición de la táctica

Reúne las técnicas mediante las cuales un adversario mantiene comunicación con sistemas comprometidos para controlarlos remotamente.

13.2. Aplicación hipotética al objetivo

De existir un compromiso, el adversario *podría* establecer un canal de mando y control mediante:

- Protocolos de aplicación estándar (T1071), como HTTPS, para camuflar el tráfico C2 dentro del tráfico web legítimo del servidor.
- Servicios web legítimos de terceros como canal encubierto (T1102).

13.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
Cobalt Strike	Framework comercial de post-explotación y C2, ampliamente utilizado en pruebas de intrusión autorizadas.
Metasploit (módulo handler)	Establecimiento de canal C2 tras la explotación.
Sliver / Empire	Alternativas de código abierto a Cobalt Strike.

13.4. Nota ética

No se estableció ningún canal de comunicación con el servidor objetivo más allá de las consultas legítimas de reconocimiento documentadas en el Capítulo 1.

Capítulo 14

Exfiltración (Exfiltration – TA0010)

14.1. Definición de la táctica

Comprende las técnicas utilizadas para extraer datos desde la red comprometida hacia un destino bajo control del adversario.

14.2. Aplicación hipotética al objetivo

De haberse recolectado información (Capítulo 12), un adversario *podría* exfiltrarla mediante:

- Exfiltración sobre el canal C2 ya establecido (T1041), aprovechando el mismo canal HTTPS.
- Túnel de exfiltración por DNS, técnica difícil de detectar por firewalls tradicionales.
- Envío a servicios de almacenamiento en la nube legítimos (T1567), para camuflar el tráfico saliente.

14.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
DNSExfiltrator	Exfiltración de datos mediante consultas DNS.
Rclone	Sincronización con servicios de almacenamiento en la nube, abusable para exfiltración.
`curl` / `scp`	Transferencia directa de archivos hacia un servidor externo.

14.4. Nota ética

No se extrajo ningún dato del sistema objetivo; sección exclusivamente conceptual dentro del marco teórico de la matriz ATT&CK.

Capítulo 15

Impacto (Impact – TA0040)

15.1. Definición de la táctica

Es la táctica final de la matriz e incluye las técnicas orientadas a manipular, interrumpir o destruir sistemas y datos, afectando la disponibilidad, integridad o confidencialidad del servicio.

15.2. Aplicación hipotética al objetivo

En el peor de los escenarios, y únicamente con fines ilustrativos del alcance final de la cadena de ataque, un adversario que hubiera avanzado por todas las fases anteriores *podría* causar:

- Denegación de servicio (T1499), dejando fuera de línea el aula virtual durante períodos críticos (exámenes, matrículas).
- Defacement del sitio web institucional (T1491), afectando la imagen de la universidad.
- Cifrado malicioso de datos (ransomware, T1486), comprometiendo la disponibilidad de la información académica.

15.3. Herramientas asociadas (referenciales)

Herramienta	**Uso típico**
LOIC / HOIC (mencionadas solo con fines académicos)	Herramientas históricamente asociadas a ataques de denegación de servicio.
Scripts de cifrado personalizados	Base conceptual de un ataque de ransomware.

Capítulo 16

Mitigaciones y Defensas

16.1. Introducción

Este capítulo consolida las medidas de mitigación recomendadas frente a las 15 tácticas de la matriz MITRE ATT&CK analizadas en los capítulos previos. Se prioriza lo identificado realmente en el reconocimiento (Capítulo 1), y se complementa con controles preventivos generales para el resto de la cadena de ataque.

16.2. Mitigaciones priorizadas (hallazgos reales del reconocimiento)

Hallazgo	**Mitigación recomendada**
SSH expuesto públicamente con autenticación por contraseña	Restringir el puerto 22 a IPs/VPN autorizadas; deshabilitar `PasswordAuthentication` y permitir solo autenticación por llave pública; instalar `fail2ban` para bloquear intentos repetidos.
Algoritmos criptográficos débiles en SSH (SHA-1, curvas NIST)	Editar `/etc/ssh/sshd_config` retirando los algoritmos marcados como `[fail]`/`[warn]` por `ssh-audit`; conservar únicamente Curve25519, ChaCha20-Poly1305 y MACs `-etm` modernos.
CMS Drupal identificado	Mantener Drupal y sus módulos actualizados a la última versión estable; suscribirse a los avisos de seguridad oficiales de Drupal.
Contacto administrativo expuesto en WHOIS	Activar protección de privacidad WHOIS si el registrador lo permite; capacitar al personal en identificación de phishing dirigido.
Ausencia de listado de directorios/archivos verificable	Revisar periódicamente la superficie expuesta con `gobuster`/`ffuf` propios y retirar archivos sensibles (backups, `.env`) del directorio público.

16.3. Mitigaciones por táctica MITRE ATT&CK

Táctica	**Mitigaciones recomendadas**
Reconocimiento	Minimizar información pública expuesta (WHOIS privado, cabeceras de servidor genéricas); monitorear escaneos externos con IDS/IPS.
Desarrollo de Recursos	Registrar variantes comunes del dominio propio (defensa contra typosquatting); monitoreo de certificados emitidos vía Certificate Transparency (crt.sh) para detectar clones.
Acceso Inicial	Aplicar parches de seguridad de forma oportuna (gestión de vulnerabilidades); Web Application Firewall (WAF) delante del CMS; filtrado de correo anti-phishing.
Ejecución	Listas blancas de aplicaciones (application allowlisting); deshabilitar intérpretes de scripting innecesarios en el servidor.
Persistencia	Auditoría periódica de cuentas y llaves SSH autorizadas; revisión de tareas cron y servicios habilitados.
Escalada de Privilegios	Principio de mínimo privilegio en configuraciones `sudo`; actualización regular del kernel; eliminar binarios SUID innecesarios.
Sigilo (Evasión de Defensas)	Envío de logs a un servidor centralizado (SIEM) fuera del alcance del atacante, para impedir su alteración local.
Alteración de Defensas	Proteger la configuración del firewall y de `fail2ban` con permisos restringidos; alertas ante cambios no autorizados en reglas de `iptables`/`nftables`.
Acceso a Credenciales	Autenticación multifactor (MFA) en todos los accesos administrativos; políticas de contraseñas robustas; deshabilitar autenticación por contraseña en SSH.
Descubrimiento	Segmentación de red (VLANs) para limitar la visibilidad desde un host comprometido hacia el resto de la infraestructura.
Movimiento Lateral	Segmentación de red y firewalls internos; deshabilitar reutilización de credenciales entre sistemas.
Recolección	Cifrado de datos sensibles en reposo; control de acceso estricto a bases de datos del CMS.
Mando y Control	Filtrado de tráfico saliente (egress filtering); inspección profunda de paquetes (DPI) para detectar tráfico C2 anómalo.
Exfiltración	Prevención de pérdida de datos (DLP); monitoreo de volúmenes inusuales de tráfico saliente.

Táctica	Mitigaciones recomendadas
Impacto	Copias de seguridad periódicas y probadas (offline/inmutables); plan de continuidad y respuesta a incidentes documentado.

16.4. Recomendación final

Se recomienda a la Oficina de Tecnologías de la Información de la UNAP priorizar, en el corto plazo, las mitigaciones de la Sección 16.2 (hallazgos reales verificados), por ser las únicas confirmadas mediante evidencia técnica directa durante este trabajo. Las mitigaciones de la Sección 16.3 corresponden a buenas prácticas preventivas generales frente al resto de la cadena de ataque, aplicables independientemente de si dichas fases llegaran a materializarse.